WAZO MOJA SELF-HELP GROUP

The Chama System: who uses it, and what they get

How each person works in the system — step by step — and what comes back to them in return: their passbook, their reports, their documents, their limits.

Version	1.0 — 22 September 2026
Applies to	Wazo Moja Self-Help Group contribution system (live at https://wazomojashg.co.ke)
Written from	The code as it stands in this repository, after the permissions pass of 22 September 2026
Reads with	ROLES_AND_PERMISSIONS.md (rewritten in the same pass) and Annex D, which lists what changed
Read it with	Annex A (screens by role), Annex B (API by role), Annex C (glossary)

Six kinds of user are described: a member — who never signs in — and five staff roles. The member's part of the system is the public half of the application; everything else is reached from one sign-in page.

Contents

Contents 2
1. How to read this guide 4
2. The system in one minute 4
3. The six users at a glance 4
4. The member — no account, one key 5
4.1 What he sees when he opens the site 5
4.2 The gate: how he gets in 5
4.3 His own record: the passbook 6
4.4 What he can download 6
4.5 The members' area: documents, minutes, the constitution 6
4.6 What a member can never do 7
4.7 A member's five minutes, step by step 7
4.8 If a member says the figure is wrong 7
5. Staff accounts: what every role shares 7
5.1 Getting in 8
5.2 Two-factor authentication (2FA) 8
5.3 The menu each role gets 8
5.4 What the office dashboard is 9
6. The super admin — the account that can put things right 9
6.1 The account itself 9
6.2 Work only the super admin can do 9
6.3 A super admin's working session 10
6.4 Backups on the free host 10
6.5 The Control Room 10
6.6 What even the super admin cannot do 11
7. The admin — the office, day to day 11
7.1 The account 11
7.2 What the admin does — and gets 12
7.3 What an admin cannot do 13
7.4 The two fine decisions worth knowing 13
7.5 Loans, and the one decision that is the admin's 13
8. The treasurer — the ledger, the week cycle and the numbers 14
8.1 The account 14
8.2 The ledger, as the treasurer works it 14

8.3 What the treasurer gets out 14
8.4 What the treasurer cannot do 15
8.5 A Thursday close, step by step 15
8.6 The three fields the treasurer may fill in but not replace 15
9. The secretary — the group's paperwork, and reading the books 16
9.1 The account 16
9.2 The minutes — what the secretary is for 16
9.3 The document vault 16
9.4 Reading the books — Reports 16
9.5 What the secretary cannot do 17
9.6 A meeting, step by step 17
10. The disciplinary officer — fines, and nothing else 17
10.1 The account 17
10.2 The screen 17
10.3 What the officer gets out 18
10.4 What the disciplinary officer cannot do 18
10.5 Issuing a fine, step by step 18
11. Who can manage whom 18
12. The access matrix 19
13. Common tasks, step by step 20
14. The money rules every user shares 22
15. Security, privacy and the audit trail 22
15.1 What is public and what is not 22
15.2 The defences that matter in daily use 23
15.3 The audit trail — what it holds, and who reads it 23
15.4 Backups 23
16. What only one person can do — and why that matters 24
Annex A — every screen, and who may open it 24
Annex B — the API, by role 25
Annex C — the words this system uses 26
Annex D — what was tightened on 22 September 2026 27
Annex D2 — what was added in October 2026 28
Annex E — keeping this true 28

1. How to read this guide

This guide answers two questions for every person who touches the chama system: how do I work in it, and what do I get out of it? It is written for the committee, for whoever hands a new office holder their first sign-in, and for the developer who has to keep all of this true after the next change.

It is deliberately concrete. Each of the six user types has its own chapter that says where the person gets in, what is on their screen, the jobs they do with it, the documents and reports they walk away with, and — just as important — what the system refuses them.

- **A member** is not an account. He is a person with an ID number the office recorded for him.
- **Five staff roles** hold accounts: super admin, admin, treasurer, secretary and disciplinary officer.
- **Every staff action is recorded.** The audit trail is described in section 15.
- **The code is the source of truth.** This copy was written after a pass in which the roles, the notes and the code were brought into line with each other; Annex D lists what moved and why, so nothing here has to be taken on trust.

Where a sentence says the API refuses something, it means the server refuses it whatever screen it came from: the menus hide a destination, the route guards redirect, and the API is the part that actually decides. A URL is never the protection.

2. The system in one minute

The chama system is the group's book, kept on a phone. It replaces the paper ledger for weekly contributions, tea (chai), fines and expenses, and it adds what paper cannot: every member can read his own record at any hour, the reports build themselves, the minutes and the group's papers are filed in one place, and every change is signed with the name of whoever made it.

- **It is phone-first.** Almost all use is on a phone, on Kenyan mobile data. The members' page loads on its own, without any of the office's screens.
- **There are exactly two doors:** the public page at / — open to anyone, but a member's own figures appear only after his ID is typed — and /admin/login, the office.
- **Members never sign in and never hold a password.** The ID number the office recorded for them is the key, and it opens only their own record.
- **One shared week number** advances by itself every Friday, closing on the Thursday. Nobody ever has to start a week, and no two screens can disagree about which week it is.
- **Tea is automatic**, deducted for every closed week, so it is never in arrears and never needs an entry (section 14).
- **Everything a person changes is audit-logged** with a before-and-after snapshot, in an append-only chain that flags the entries worth a second look.
- **The whole database fits in one downloadable file** — super admin only, and it is treated the way the register itself is treated.

Under the bonnet, for whoever has to run it: a React/Vite/Tailwind front end, a Node/Express API with MongoDB behind it, and JWT sign-ins for staff only. Members are never authenticated.

3. The six users at a glance

One page to keep on the wall. Everything after this is the detail behind these rows.

User	Account?	Gets in at	Lands on	What they are for
Member	None, ever	/ — types his ID	His own passbook	Reads his own record, the group's

		number		documents, minutes and constitution
Super admin	Yes	/admin/login	/admin/dashboard	Owns the system: accounts, settings, the group's 2FA and fine policy, backups, jobs
Admin	Yes	/admin/login	/admin/dashboard	Runs the office: money, members, fines, minutes, documents, reports
Treasurer	Yes	/admin/login	/admin/finance	Keeps the ledger, the week cycle and the opening balances; reports on it
Secretary	Yes	/admin/login	/admin/minutes	Writes the minutes and files the group's documents; reads the books, changes nothing else
Disciplinary officer	Yes	/admin/login	/admin/disciplinary	Issues disciplinary fines and produces a member's fine record

Only three roles can reach the dashboard: super admin, admin and treasurer. The secretary and the disciplinary officer are sent to their own working screen instead, because a dashboard of member balances is not a screen either of them logs money from.

4. The member — no account, one key

A member is the reason the system exists, and the only user who never signs in. He has no password, no username and nothing to enrol: he has the ID number the office recorded for him, and that opens his own page and nothing else.

4.1 What he sees when he opens the site

The public page is a single screen on a phone. Above his own record it shows the group itself: the name and logo, how many members there are, what each fund has raised, what came in over the last seven days, and the vision and mission. That part is deliberately impersonal — it carries no member's name, balance or phone number, and there is no public directory of members anywhere in the system.

4.2 The gate: how he gets in

- **The key is his ID, exactly as the office recorded it.** Spaces, dashes and slashes are ignored, and a passport number's letters are accepted, so "12 345 678", "12345678" and "A1234567" all work.
- **Active members only.** A resigned member's number opens nothing.
- **One member, or nothing.** The gate does not offer similar names and never shows a list: the wrong number simply opens nothing.
- **If the register holds the same ID twice**, the gate refuses and says so — it will not guess which of the two members is answering, and it asks him to have the treasurer check the register.
- **Guessing is slow by design.** Five lookups a minute per connection is the limit on the passbook (a short number written on a card is worth capping), thirty a minute for the documents, minutes, constitution and the group totals. Every refusal is written to the log as a short hash of the number, never the number itself.
- **Phone numbers are not a key any more.** The old public pages accepted them; nothing on the members' side does now.
- **No ID, no way in.** A member whose record holds no usable ID (blank, or a note such as "not yet issued") cannot open anything — which is why the office's Members page counts how many are still in that state and chases them.

What he is told when it fails: "Enter a valid ID number, e.g. 12345678 (or a passport number)" when the entry is not an ID at all; nothing found when no active member holds it; and the duplicate message above when two records share it.

4.3 His own record: the passbook

Once the ID is accepted, his record reads like the page the treasurer keeps for him:

- **What he holds, and how it is made.** His opening balance, what he has paid since the cycle opened, what has been required of him so far, the tea taken, and the money left. Next to it, his arrears (or his credit) and how many weeks he has paid against how many have closed.
- **Every payment he has made**, with the date, the method and the note the office typed — often the M-Pesa or bank message itself.
- **What he has put into each fund**, with his own weekly contribution named.
- **His fines**: pending and settled, each with its type, reason and date, and the total still owed.
- **His own details**: name, registration number, photograph, join date, and his phone number shown partly hidden — even to him, because a shared screen or a screenshot should not hand his number out.

Two things appear only when he has proved his own number at the gate: his email address, his list of next of kin, and whether he receives email reminders. Somebody who types a number that is not theirs gets a record without them.

Where it all sits on the page. His record opens first, because that is what he came for. While he is still looking at the page without a record, the whole top of it is the one question — what the group does, and the box for the ID registered with it. The moment the ID is accepted that block stands down to a single line, "Record open · Member № 12345", with a button to check another ID; his record then begins at the top of the screen instead of below a headline and a form he has already used.

His passbook is laid out as a small dashboard: his name and member number above everything, then — under his name on a phone, and in a column down the right-hand side on a laptop screen — the one figure the page exists for (**what he holds today**, with the sum it is made of spelled out under it, and anything he owes), followed by his details, his next of kin and his statement downloads. The ledger itself — every payment, newest first, with what he has paid to date — takes the wide side of the page, with his fines and his week-by-week schedule beneath it, because a ledger is the one thing that needs the room. What is left is the group's own figures and its vision and mission, in a band of their own behind their own heading: the part anybody may read without an ID, marked as something different from his record.

4.4 What he can download

- **A statement as a PDF** — the printable copy, for a meeting, a bank or a family conversation.
- **A statement as an Excel workbook** — a sheet per question, so the figures can be checked or reused rather than only read.
- **A period, if he wants one:** the whole book by default, or a year, a quarter, or a range of dates of his choosing.

The office prints the same statement from exactly the same figures, so the two can never tell different stories. The one difference is deliberate: the member's copy names his own weekly contributions and does not carry the Group's Tea Fund line, which is the group's own account.

4.5 The members' area: documents, minutes, the constitution

The same ID opens three more tabs, so a successful passbook lookup counts as having entered it — he is never asked twice in one sitting. Every tab is served by an endpoint that checks the ID again on every request, so the unlock on screen is a convenience, never the protection.

- **Documents.** The group's papers that the office has published to members — title deeds, certificates, registration papers — listed under the headings the office files them by. A PDF or an image opens in the browser; anything else is downloaded rather than opened.

- **Minutes.** The meetings the secretary published. He can search every word of every published minute and a result opens with the sentence the word was found in, marked. A minute withheld from members is never reachable here.
- **The constitution.** Chapter by chapter, on its own page, with his own verdict shown against each chapter he has already answered.

The one thing a member writes. On the constitution he may approve or reject a chapter, with a reason. One decision per chapter per member is enforced by the database, so a double tap cannot rewrite it, and the record cannot be edited afterwards — by the office either. The office sees the same rows on the member's profile that he sees on his own reading page.

4.6 What a member can never do

- See another member's record, balance, phone number, email or next of kin.
- Browse a list of members: no such list exists on the public side.
- Sign in anywhere, or reach any office screen.
- Change money, his own record, or his own fine — the constitution verdict is the only write he has.

4.7 A member's five minutes, step by step

1. Open the group's address on his phone. The page loads without any office code behind it.
2. Type the ID the office recorded for him and press the button.
3. Read the figures that make his money: opening balance, paid since the cycle opened, required so far, tea taken — and what is left.
4. Check his own payments, week by week, and any fine outstanding against him.
5. Download the statement: PDF to print or share, Excel to keep and check. Narrow it to a year, a quarter or a range of dates first if that is what is wanted.
6. Open the documents, the minutes or the constitution from the same page.

4.8 If a member says the figure is wrong

The passbook is not a summary of the office's screen — it is the same arithmetic, from the same engine, over the same rows. So a disagreement is almost always about the entries, not the totals: a payment keyed against the wrong week, or against another member, or a payment that was never keyed at all. What to do:

- Ask which week he is looking at, and check the ledger for that member and that week.
- Look at the note on the payment — the office writes the M-Pesa or bank message into it, which is usually enough to place it.
- Hand him the same statement the office prints from his page, so the two of you are reading one document rather than two screens.
- If the member has no ID on the register, that is the first thing to fix: without it he cannot open his own record at all.

5. Staff accounts: what every role shares

Five roles, one sign-in page, and the same ground rules for all of them. Read this once and the chapters that follow only have to describe what is different.

5.1 Getting in

- **Accounts are created, never self-registered.** An admin creates one and sets the password at that moment. There is no sign-up page for anyone, and no "forgot password" link: the system sends no email for that, by design, so an admin resets it instead.
- **Password policy:** at least eight characters, with letters and numbers.
- **Sign-in is one step, or two when the group has two-factor on.** Email and password; then, if the account has a second factor, a code from the authenticator app (or one of the recovery codes). The password step and the code step happen on the same page, and the code is only valid for five minutes.
- **Guessing is slow.** Sign-in attempts are limited per address and per connection, so a script working through a list of addresses runs out of budget quickly.
- **A session lasts eight hours.** Changing a password ends every other session of that account — including a thief's. Signing out clears the token in that browser.
- **Where each role lands:** super admin and admin on the dashboard, the treasurer on the finance ledger, the secretary on the minutes, the disciplinary officer on the discipline screen. It is where that role can actually start work.
- **A screen is never the permission.** The menu hides what a role may not open, the route guard sends a blocked URL to that role's own landing screen, and the API refuses the same request regardless of where it came from.
- **My account** (`/admin/account`) is one screen every role can open — from the Account link in the top bar on a phone, or My account in the sidebar. It carries the password form and the second-factor panel, which is the only place a treasurer, secretary or disciplinary officer can do either.
- **Weak signal is expected.** The app keeps working offline: work that was marked as such goes into an outbox on the phone and is sent when the connection returns.
- **Every write is recorded.** Who created, edited, deleted, settled or voided what, with the before and after (section 15).

5.2 Two-factor authentication (2FA)

- **Off for the group until the super admin turns it on** (Settings → Security). While it is off, nobody can enrol — off means off, whether or not an account had set it up before.
- **Enrolling is three steps** from Settings → Security: get the secret and scan it with an authenticator app, then type a code from the app to prove it works. Nothing switches on until that code is accepted, so a half-finished setup can never lock anybody out.
- **Ten recovery codes** are issued with it, for a lost phone or a dead battery. Using one is announced when it happens, and the screen says when the last one is gone.
- **Who can enrol:** every role. The panel lives on My account, which any signed-in role can open — so turning the group's switch on protects every account that enrols, not just the admins'. (Before this screen existed, the panel was on the Settings page alone, which admins are the only roles that can open.)
- **A lost phone is an admin job:** the super admin can reset any admin's second factor, and an admin can reset a secretary's or a disciplinary officer's. Resetting clears it completely, so the account signs in with a password alone until it enrols again — which is why it is loud in the audit trail and why the password should be changed at the same time.
- **Turning it on or off for the whole group is the super admin's decision alone.**

5.3 The menu each role gets

The same list drives the bottom bar on a phone (four tabs and a "More" sheet) and the sidebar on a wider screen. Settings is reached from the dashboard rather than the bar, and My account sits outside the list altogether because every role has it.

Role	Menu destinations
Super admin	Dashboard · Members · Finance · Reports · Minutes · Reminders · Docs · Audit · Discipline (+ Settings, My account)
Admin	Dashboard · Members · Finance · Reports · Minutes · Reminders · Docs · Audit · Discipline (+ Settings, My account)
Treasurer	Dashboard · Members · Finance · Loans · Reports · Reminders · Docs (+ My account)
Secretary	Reports · Minutes · Docs (+ My account)
Disciplinary officer	Discipline (+ My account)

5.4 What the office dashboard is

For the three roles that hold it, the dashboard is the logging screen: the week's figures and the member list, eight names deep, with the full list one tap away on Finance. A tap on a name opens that member's ledger panel over the list — no page change — which is where money is actually logged. Beside it, the "Go to" panel groups every other destination by what the group does: Money, Records, Administration.

6. The super admin — the account that can put things right

One account owns the system. It is the only account that can create another admin, change what everyone else must do to sign in, take a copy of the whole database, or run the scheduled work. It also has every right the admin and the treasurer have.

6.1 The account itself

- **It is made once, on the server**, not from a screen: `npm run seed:super-admin -- "Full Name" you@example.com "a-strong-password"`. The command refuses to run while a super admin already exists.
- **It cannot be deactivated from any screen.** The API refuses, because it is the account that has to be able to put things right.
- **Its own password is changed from Settings → My password.** If that password is lost, it is reset on the server with the account holder present: `node src/scripts/resetSuperAdmin.js "Full Name" email "new-password"`. There is no email route to it, by design.
- **Nothing it does is anonymous.** Every account it creates, resets, deactivates or switches leaves an audit entry naming it.

6.2 Work only the super admin can do

- **Accounts:** create, deactivate, reactivate, reset the password of, and reset the second factor of, any account — including other admins.
- **The group's second factor:** switch two-factor authentication on or off for everybody at once (Settings → Security). While it is off, nobody may enrol.
- **How money meets fines:** decide whether a logged payment pays down outstanding fines before it counts as contribution. It is off unless deliberately switched on, because it changes what the books say about money.
- **Backups:** download the whole database — documents included — from Settings → Backup, and read the two lines above the button: when a copy last left the machine, and what is merely sitting on the host. A "slim" copy leaves the document scans out, for reading or emailing rather than restoring.
- **The scheduled work:** the nightly backup, the weekly audit check and the reminder sweep — what they are, when they run next, what they last did, and a way to run one by hand.

- **The Control Room** (Control Room in the menu): one screen for seeing the whole system and putting it right. Section 6.5 describes it.
- **Everything else**, exactly as the admin and the treasurer have it: the ledger, members, fines, minutes, documents, reports, reminders, loans and the audit trail.

6.3 A super admin's working session

- **The dashboard** — the week's figures and the member list; the "Go to" panel beside it holds the whole map.
- **Settings → Chama identity** — the group's name, logo, vision and mission, and the date weekly tracking starts from.
- **Settings → Fine types** — what each infraction costs, in both the financial and the disciplinary categories.
- **Settings → Accounts** — who can sign in and as what; deactivate rather than delete; reset a password; reset a lost second factor.
- **Settings → My password** and **Settings → Security** — the account's own hygiene, and the group's master switch.
- **Settings → Backup** — take a copy, and check that the last one actually left the machine.
- **The office's work** — logging money, members, fines, minutes, documents, reports and the audit trail, all of it available.

6.4 Backups on the free host

- **Each backup is also kept off the server.** The host the system runs on may wipe its own disk whenever it restarts, so a copy sitting there is not a backup. Every backup is also compressed and stored, privately, in the same Cloudinary account the photographs use; the newest 14 are kept. Only the super admin can list, download or restore from them (Control Room → Backups).
- **The 02:00 backup only happens if the server is awake at 02:00.** The free plan puts the server to sleep when nobody is using it, and the group has chosen not to keep it awake with an outside timer, because that spends the month's free hours and the service is then switched off until the month turns. So on most nights the scheduled backup does not run.
- **Take it by hand instead.** Control Room → Backups → Run now on nightly-backup makes the copy and sends it off the server in one go. Do it after any day money was recorded, and before anything risky (a restore, clearing the rehearsal's money, merging two members).
- **The reminder is built in.** The Control Room raises a warning when the newest off-server copy is more than three days old, or when the last attempt failed.
- **Download one now and then.** The free database has no backups of its own, so these copies are the group's only protection against losing it. Keep a downloaded one where the committee keeps the register, never in the repository.

6.5 The Control Room

- **Needs your attention.** The first thing on the screen: what is wrong right now, most serious first. For example a backup that is old or failed, loans that are behind, errors the server has hit, or an account that looks wrong.
- **Accounts and sessions.** Everybody who can sign in: their role, when they last signed in and were last active, and from where. You can sign an account out everywhere, freeze it with a reason (it takes hold on the very next request, not when the session expires), or see the app as that role sees it. An account that pre-dates sign-in tracking says "no sign-in recorded yet" rather than "never".
- **See the app as someone else.** A 30-minute, read-only preview of what a treasurer, secretary or other role sees. Every change is refused while previewing, and the Control Room itself is not reachable from inside it.
- **Maintenance mode.** Stops everyone but the super admin from changing anything, with a message you write. Sign-in stays open, because locking out sign-in would lock out the one person who has to switch it off.

- **Closing the books.** Pick a closing day; money dated on or before it can no longer be added, changed or voided. The super admin can still go through with a written reason, which is recorded in the audit trail before the change it allowed.
- **Switches.** Turn the members' page, fine emails, reminder emails and the constitution vote on or off without a redeploy. All are on unless you switch them off.
- **Backups, restore and jobs.** The nightly backup, the weekly audit check and the reminder sweep (pause, run now, history); the off-server copies (list, download); and restore. Restore is two steps: first look at a file (nothing is written), then restore, which needs maintenance mode, your password and the word RESTORE, and takes a safety copy of today first. It only adds and replaces; it never empties anything.
- **Server errors.** Every time the server itself fails (not a mistyped form: a fault), it is recorded, grouped by what and where, and counted. You are emailed once per distinct fault every six hours, and the last week's are listed here.
- **Danger zone.** Clear the rehearsal's money before go-live: contributions, expenses and fines are marked deleted (never hard-deleted); members, accounts, settings and opening balances stay. Needs maintenance mode, your password, the phrase RESET REHEARSAL DATA and a safety copy that succeeded.
- **Merge two members.** For a member entered twice: moves his contributions, fines, opening balance and constitution votes onto the record kept and retires the duplicate with a note saying where it went. Nothing is deleted. A preview shows what will move first.
- **Who can do what.** A generated table of every screen and address against every role, read from the code itself, so it cannot drift from what the server actually enforces.

  Behind the screen: every address under /api/superadmin is refused to every role but the super admin, and a test fails if a new one is added without that guard. The Control Room does not repeat the Audit screen's oversight tables; it counts them and links there.

6.6 What even the super admin cannot do

- Deactivate or delete the super admin account; reset its own password through the accounts list (Settings → My password is the way), or use the accounts list to switch its own second factor off.
- Change the weekly amount, the tea amount, the week number or each member's opening balance from Settings — those are on Finance → Setup, deliberately, so that a save which would move every balance is confirmed first and audited as one change.
- Change history quietly: the audit trail is append-only and chained, so an entry cannot be edited or removed afterwards.

  Behind the screen: this role is the only one the API admits to /api/backup and /api/jobs, and the only one whose request can carry twoFactorAuthEnabled or autoSettleFines to /api/settings.

7. The admin — the office, day to day

The admin is the role the group's daily work runs on: money in, money out, members, fines, minutes, documents, reports. The treasurer's ledger work is included — the difference between the two is that only the super admin can create an admin or change what the whole group must do.

7.1 The account

- **Created by the super admin.** A plain admin may not create or manage another admin: the API answers "Only the super admin can create an admin account".
- **Lands on /admin/dashboard** and holds the same menu as the super admin, except that Backup is not on the Settings page for this role.

- **Can manage the secretary and the disciplinary officer**: create, deactivate, reactivate, reset password, reset a lost second factor. Not the treasurer and not another admin.

7.2 What the admin does — and gets

- **Logs money.** Dashboard (or Finance) → tap the member → the ledger panel: a weekly contribution, an extra payment, the tea or an expense, each with the date, the method and a free-text note for pasting the M-Pesa or bank message. If the group has switched it on, the payment pays off pending fines oldest-first as it is logged.
- **Keeps the members' register.** Add, edit, resign (never delete), attach a photograph, import a spreadsheet of members from the template, export the register as a real .xlsx, and see at a glance how many active members still have no usable ID.
- **Prints a member's statement.** Any period — the whole book, a year, a quarter or a range — as a PDF or an Excel workbook.
- **Emails a member his own statement.** *Email statement* on the member's page sends the same PDF his passbook downloads, for the period chosen beside the button, to the address on his record. It is held back when there is no usable address or he has switched emails off, it sends at most three a day to one member, and every send is in the audit trail.
- **Lends to members.** Loans (Money menu): amount, one flat interest rate charged once on the amount lent, and the number of months. See section 7.5.
- **Sets a spending limit.** Settings → Spending limit. Above it, an expense or a loan must say which meeting's minute approved it (an *Approved in* box that appears only above the limit). Zero, which is how it starts, means no limit.
- **Issues, settles and voids fines.** Issue from the member's page or the discipline screen, settle a fine that has been paid, and void one that should never have been issued.
- **Runs the go-live figures.** Finance → Setup: the weekly amount, the tea amount, the week number, each member's opening balance, each fund's carry-in, and the one-time whole-week collection with its preview and its undo.
- **Sets up the funds and their types.** Contribution types and fine types, with banks/teas classified as funds or as members' own contributions.
- **Writes and publishes the minutes**, imports an existing Word document into the editor, searches every word of every minute, and decides which minutes members may read.
- **Runs the document vault**: upload the group's papers (up to 8 MB each), publish them to members or hold them back, and manage the headings they are filed under.
- **Emails whoever is behind.** The Reminders screen lists who owes what from the same weekly schedule the members' own passbooks show, so an email can never claim something a statement contradicts. Each member has a weekly budget — Settings → Reminders, one reminder a week by default — so the same member is not told the same thing every few days: the row says how often he has already been emailed this week, a member at the limit cannot be ticked unless somebody deliberately ticks **Send anyway**, and the bottom of the screen lists who has actually been emailed, in what words, when and by whom.
- **Reports and exports**: summary, trend over recent weeks, weekly reconciliation, member performance, monthly totals and the fines report — each one downloadable as .xlsx. The fines report's **Who owes what** is the list the office works from: how many members owe, how much between them and how far back the oldest debt goes, a search by name, registration number or phone, the order wanted today (most owed, most fines, longest owing, name), and a tap on any member for what he owes it for — his debt split by fine type, biggest line first.
- **The audit trail**: filtered by money, people, records or settings, by who, by date and by free text, with the unusual entries flagged and the view on screen exportable.
- **The group's identity** (name, logo, vision and mission), the fine types, the secretary's and disciplinary officer's accounts, and its own password and second factor — all from Settings.

7.3 What an admin cannot do

- Create or manage another **admin**, or create or manage a **treasurer**. The API admits only the super admin to those; the accounts screen offers Treasurer to this role, so expect the refusal and read Annex D.
- Deactivate the super admin, or change the group's two-factor switch or the fine-settlement policy — those are the super admin's alone.
- Download a backup or run a scheduled job: both screens are super-admin only.
- Hard-delete a member. Records are kept, with a resignation date and reason instead.

7.4 The two fine decisions worth knowing

- **Settle** is for a fine that has been paid: the member's page → Fines → Pay. A logged contribution can settle fines for you, oldest first, when the group's fine-settlement switch is on.
- **Void** is for a fine that should never have been issued — not for one that has been paid. Voiding is audited and the fine disappears from the member's owed total.
- The disciplinary officer may issue fines but never settle or void them, and never sees the financial ones. That split is the point of having two roles.

Behind the screen: /api/members, /api/contributions, /api/expenses, /api/loans, /api/ledger, /api/types, /api/fines (settle and void), /api/fine-types (write), /api/minutes (write), /api/documents (write), /api/notifications, /api/uploads, /api/settings and /api/auth/admins.

7.5 Loans, and the one decision that is the admin's

- **How a loan works.** The treasurer or admin records the amount, the interest (one flat percentage on the amount lent, charged once, not per month) and the number of months. The system works out the monthly instalment and the date each one falls due. There are no guarantors; that was the committee's choice.
- **Repayments** are recorded as they come in, whatever the amount. Each is split between principal and interest in the proportion the loan was priced in, so the two add up to the cent however the member pays. Paying more than is owed is refused, with the figure.
- **Who is behind.** A loan is behind once an instalment's date has passed and the total paid does not cover it. The Loans screen, the member's own page and the Control Room all say by how much and for how many days.
- **It does not disturb the group's figures.** Money lent counts as *owed back*, not *spent*, so what the group holds does not drop when it lends. Each repayment gives back its share of principal and only the interest counts as income. Do not edit or delete a loan's expense from Expenses; the system refuses. Record a repayment, take the last one back, or cancel instead.
- **Taking back and cancelling.** Only the most recent repayment can be taken back. A loan with nothing repaid can be cancelled, with a reason, and the books forget it.
- **Choosing the loan fund is an admin's decision, not the treasurer's.** The first time, the group has to say which fund is its loan fund. Doing so changes how money already paid out of that fund is counted (it stops being *spent* and becomes *owed back*), which raises what the group is shown as holding. The screen says by how much and asks for confirmation first.
- **A member with a loan out cannot be resigned** without writing down what became of it, as with money he holds or fines he owes.
- **Not built:** writing off a loan nobody will repay. It needs the committee to decide how to show the loss; until then a loan stays on the books until repaid or, if made in error, cancelled.

8. The treasurer — the ledger, the week cycle and the numbers

The ledger is this role's workspace. The treasurer logs the money, owns the week cycle and the opening balances, and is the person the reports are built for.

8.1 The account

- **Created by the super admin.** A plain admin cannot create a treasurer account — the API admits only the super admin, and Annex D explains the screen that offers it anyway.
- **Lands on /admin/finance**, not the dashboard: the member list they log against is the screen they need.
- **Menu:** Dashboard · Members · Finance · Loans · Reports · Reminders · Docs. (There is no Audit: the audit trail is for the admins only.)

8.2 The ledger, as the treasurer works it

- **Finance opens with the week.** The week number, the amount expected of each member, and this week's dates, then the member list: what each member holds, what he owes, and how many weeks he is behind. It sorts by name, by most owed or by most money held, and it searches.
- **A tap opens the member** in a panel over the list — no page change, and closing it leaves the scroll where it was. That panel is the one place money is logged: a weekly contribution, an extra payment, the tea, or an expense, each with the amount, the date, the method and a free-text note for pasting the M-Pesa or bank message.
- **Logging refreshes the list underneath**, so the next name is already correct.
- **Loans** (Money menu) lets the treasurer lend to a member, record repayments, take the last one back and cancel a loan made in error, and shows who is behind (section 7.5). Choosing which fund is the loan fund is the admin's decision, not the treasurer's.
- **Email statement** on a member's page sends him his own statement as a PDF, for the period chosen, to the address on his record (at most three a day to one member).
- **Finance → Setup is the go-live sheet:** the weekly amount, the tea amount, the week number and the week anchor, then every member's opening balance (with "Use all suggestions" to fill them from the ledger), each fund's one-time carry-in, and the one-time whole-week collection — which previews before it posts and can be undone.
- **A save that would move the books hard asks twice.** Cutting the members' total by a quarter or more comes back for confirmation, and the whole save is written to the audit trail as one entry naming the treasurer.

8.3 What the treasurer gets out

- The week's figures, every member's opening balance, paid, required, tea and money held — on screen and in the member's own statement.
- **Statements** for any member, as PDF or Excel, for any period.
- **Reports**: summary and the trend over recent weeks, the weekly reconciliation (expected against actual, with the members' contributions named), member performance, monthly totals and the fines report — each exportable as .xlsx for a meeting or an auditor.
- **Reminder emails** to whoever is behind, built from the same weekly schedule the members' passbooks show.
- **The register export** (.xlsx or CSV). Not the audit trail: that is for the admins only, and an admin can export it for a meeting.

8.4 What the treasurer cannot do

- **Replace a member's ID number, phone number or next of kin** once the record holds one. Filling in what is missing is his — it is most of what the office is doing, since so many members have no ID on file yet — but those three fields are the member's key to his own record, the office's line to him, and somebody else's contact details, so replacing one is an admin's decision. The form locks the box and says so (section 8.6).
- **Touch fines.** Not issue, settle or void them, and not even list the fine types — that is the office's and the disciplinary officer's ground.
- **Change the group's identity or settings**: the name, the logo and the weekly tracking start date belong to the admins.
- **Upload or remove documents.** The treasurer may read the vault, not change it.
- **Create or manage accounts**, take a backup, run a scheduled job, or open the Control Room.
- **Choose the loan fund**, or set the spending limit. Both change what the books say and are the admins'.
- **Open the minutes screen** — although the API does let this role read the minutes, since the money agreed in a meeting is exactly what a treasurer has to account for (Annex D).

The one deliberate exception: the week-cycle figures (weekly amount, tea amount, week number, anchor) are changed from Finance → Setup, which the treasurer can use, even though /api/settings is admin-only. The treasurer is the person who needs them at go-live. Changing them is a General Assembly matter, and it is audit-logged either way.

8.5 A Thursday close, step by step

7. Open **Finance**. The week's figures are at the top; sort by most owed to work the list.
8. As each member pays, tap the name and log it: weekly, extra, tea or an expense — amount, date, method, and the message pasted into the note.
9. Watch the week strip in the member's panel: paid weeks, arrears and credit per member.
10. Correct a mistake by editing the row. The old figures stay in the audit trail, so a correction is a correction and not a disappearance.
11. Open **Reminders** for whoever is behind and send one email before the week closes.
12. Open **Reports → weekly** for the expected-against-actual reconciliation, and export it for the meeting.

8.6 The three fields the treasurer may fill in but not replace

A member's record holds three fields that are more than a description of him: his ID number (the key to his own record and to the members' area), his phone number (how the office reaches him, and the members' old public key), and his next of kin (somebody else's contact details, kept because a chama has to be able to reach a family in an emergency).

- **Recording one that is missing is the office's work, whoever is holding the phone.** The register is full of records entered from a name and a phone number, and the office is chasing the members who have no ID — so the treasurer, the admin and the super admin can all fill these in, and a new member can carry them from his first day.
- **Replacing one that is already there is an admin's.** The treasurer's save is refused, the form locks the box before he tries, and the line under it says why.
- **Clearing one counts as replacing it.** The key is not taken off the door by leaving the box empty.
- **Everything else on the record stays the treasurer's**: the name, the registration number, the email, the notes, the join date, the family block, the photograph, the resignation.

The rule lives in one place in the code (backend/src/utils/memberCredentials.js) and is tested on its own, so the screen and the server cannot drift apart on it.

Behind the screen: the ledger is /api/ledger (member list, per-member log, setup, the one-time week collection), with /api/contributions, /api/expenses, /api/types and /api/members alongside it. /api/fines is not on this role's list at all.

9. The secretary — the group's paperwork, and reading the books

The secretary writes the minutes and files the group's papers, and reads the reports without being able to change any of them. It is the role a group gives to whoever keeps its records straight. It does not read the audit trail; that is the admins' alone.

9.1 The account

- **Created by the super admin or by an admin**, with the password set at creation.
- **Lands on /admin/minutes** — the screen the role actually works on.
- **Menu:** Reports · Minutes · Docs. There is no dashboard, no Members, no Finance and no Audit: the money screens are not this role's, and hiding them is how that is taught.

9.2 The minutes — what the secretary is for

- **Write a minute:** a title, the date of the meeting, and the body in a rich-text editor (headings, bold, lists, links) — the same shapes a Word document has.
- **Import an existing Word file** into the editor: it is read in the browser and its content is put into the minute being written, so an old template never has to be retyped.
- **Publish it to members, or hold it back.** One switch per minute. Published minutes are reachable by members through the ID gate; an unpublished minute is never reachable there.
- **Search every word of every minute** — the title, the body and the date as written. The search runs over the whole archive on the server, not just the rows on screen, and a result opens with the sentence the word was found in.
- **Delete a minute** — with a confirmation, and an entry in the audit trail.

9.3 The document vault

- **Upload the group's papers:** title deeds, certificates, registration documents — a real PDF or image, up to 8 MB, with a title, a heading, an optional description and a visible-to-members switch. Anything that is not a PDF or an image is refused.
- **Manage the headings.** The list is the group's own: add one and it is offered on the upload form and readable by the members the document is published to.
- **Remove a document** — with a confirmation and an audit entry.

9.4 Reading the books — Reports

- **Every report, and every export:** summary, the trend over recent weeks, the weekly reconciliation, member performance, monthly totals and the fines report — each downloadable as .xlsx. This is the role that hands figures to a meeting or an auditor.
- **One member's own chart** opens from the performance list. The report endpoint serves it, so the secretary never needs the member register to explain a figure.
- **Not the audit trail.** It is for the admins only. When an outside auditor needs it, an admin exports the view from the Audit screen and hands over the workbook.

9.5 What the secretary cannot do

- Change any money: no contributions, no expenses, no week cycle, no opening balances.
- Open the member register, the ledger or the dashboard.
- Issue, settle or void a fine, or manage contribution and fine types.
- Change the group's settings or manage any account.
- Take a backup or run a scheduled job.

Two things to know about this role today. First, writing the minutes and the documents is all it does — those are its only writes, besides a member's own constitution decision, which is not a staff action. Second, its own account is looked after from My account (`/admin/account`), the one screen every role can open: the password form and the second-factor panel live there, so this role changes its own password and enrols a second factor without an admin's help.

9.6 A meeting, step by step

13. Before the meeting, open **Minutes** and check the last record for anything carried forward.
14. After the meeting, **New**: title, date, and type the record — or import the Word file the chairman worked from.
15. Leave **Visible to members** on if the record may be read by members; switch it off for anything the committee keeps to itself.
16. Save. The minute is searchable from that moment — by the office, and by members if published.
17. When the group's papers change (a new certificate, a renewed registration), open **Docs** and upload them, under the heading that says what they are.
18. For the next meeting's figures, open **Reports** and export the weekly or monthly view.

Behind the screen: /api/reports (read and export), /api/documents (read, and write), /api/minutes (read, and write). Nothing under /api/members, /api/ledger, /api/fines, /api/audit, /api/settings, /api/backup or /api/jobs.

10. The disciplinary officer — fines, and nothing else

The narrowest staff role in the system, deliberately. It exists so a committee can put the group's discipline in someone's hands without handing over the books: this role issues fines and produces a member's fine record, and sees no other money at all.

10.1 The account

- **Created by the super admin or by an admin**, with the password set at creation.
- **Lands on /admin/disciplinary.** The menu holds one destination — Discipline — so the bottom bar on a phone is a single tab.

10.2 The screen

- **Pick the member.** A search box over the active register, matching on name, phone number, registration number or ID, so a register of thirty names is worked in one tap.
- **Pick the infraction.** Only the disciplinary category of fine types is offered to this role; the financial ones are neither shown nor issuable by it.
- **The amount comes in filled** from the type's default penalty and stays editable, because a second offence is not always the same price.
- **The date defaults to today** and can be moved back to when the offence happened.
- **Issue.** The fine lands on the member's record, in the office's reports, and in the audit trail with this officer's name on it.

10.3 What the officer gets out

- **One member's whole fine record**, as a document — the fines issued, paid off and still outstanding — for a meeting, or to hand to the member rather than read a screen aloud. The server narrows it to this role's own category, so the export is exactly what is on screen.
- **The group's disciplinary register:** totals, by type, by month and by member — who owes what, largest first, with the export listing every one of them.
- **The same Who owes what list the office works from**: searchable by name, registration number or phone, ordered the way he needs it, and every member's own row opening into what he owes it for — the fines of this category, biggest line first, each with its own date.
- **A search over the members' fines** that never leaves the disciplinary category.

10.4 What the disciplinary officer cannot do

- **Settle or void a fine.** Paying a fine off is a money action, and voiding one is a decision about whether it should ever have existed; both stay with the office.
- **See the financial fines** — the ones that belong to the ledger — or any contribution, expense or balance.
- **Open the reports, the minutes, the document vault or the audit trail.**
- **Create or change a fine type.** The prices are set once, by the admins, in Settings.
- **Reach the register's personal detail.** The screen shows what is needed to pick the right person — name, registration number, phone — and the server narrows the list to exactly those fields, so nothing about a member's family, contacts, notes or money reaches him at all.

10.5 Issuing a fine, step by step

19. Open **Discipline** and search for the member by name or phone.
20. Choose the infraction from the list. The amount fills in with the group's standard penalty.
21. Change the amount if the committee decided differently, and set the date of the offence.
22. Add the reason, then issue it. The member sees it on his own passbook at his next look, as a fine outstanding against him.
23. Afterwards, open the member's fine record to print or share it — that is the document a committee reads, rather than a screen.

Behind the screen: /api/fines (read, create, summary and both exports), /api/fine-types (read, disciplinary category only) and the member list — which the server narrows for this role to a name, a phone number, a registration number, the ID and whether the member is active. The settle and void endpoints are not open to this role at all. His own password and second factor are looked after from My account, like every other role.

11. Who can manage whom

Accounts are the one thing nobody can do to themselves. This is the whole of it, read off the API rather than off the screens.

Actor	Create	Deactivate / reactivate	Reset password	Reset a second factor
Super admin	Any role, admins included	Any account except the super admin's own	Any account; its own from My account	Any account; its own from My account
Admin	Secretary and disciplinary officer	Secretary and disciplinary officer only	Secretary and disciplinary officer only	Secretary and disciplinary officer only
Treasurer	None	None	Its own, from My account	Its own, from My account
Secretary	None	None	Its own, from My account	Its own, from My account
Disciplinary	None	None	Its own, from My account	Its own, from My account

officer				

- **The super admin hands out the two money roles.** Only he can create an admin or a treasurer; an admin creates and manages the secretary and disciplinary accounts. A role the endpoint does not serve is refused by name rather than quietly treated as something else.
- **Accounts are deactivated, never deleted.** A deactivated account cannot sign in; its history and its audit entries stay exactly where they are.
- **Nobody deactivates themselves**, and nobody resets their own password from the accounts list — that is what My account is for.
- **The super admin account cannot be deactivated at all.** It is the account that can put things right, including other accounts.
- **A password reset ends that account's other sessions**, which is usually the point of doing it.
- **A second-factor reset clears it completely**, so the account signs in with a password alone until it enrols again. Do it together with the password change, not instead of it.
- **Every one of these actions is audit-logged** with before-and-after values, under People.

12. The access matrix

The whole of the office at a glance: what each role can open, and what it can do once inside. Member is not in these tables — a member's only screen is the public one, and his only write is a verdict on a chapter of the constitution.

Money and members

Role	Dashboard	Finance ledger (log money)	Finance → Setup (week cycle, opening balances)	Members & statements	Contributions, expenses, types	Fines: read & issue	Fines: settle & void	Reports
Super admin	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Read + export
Admin	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Read + export
Treasurer	Yes	Yes	Yes	Yes	Yes	No	No	Read + export
Secretary	No	No	No	No	No	No	No	Read + export
Disciplinary officer	No	No	No	Picks a member only	No	Yes (own category)	No	No

*One row needs a footnote: the treasurer has the register — adding, editing, resigning, importing, statements — but a member's ID number, phone number and next of kin may only be *replaced* by an admin. Filling in a blank one is still his (section 8.6).*

Records, filings and oversight

Role	Minutes	Documents	Reminders (email)	Discipline screen	Audit trail	Settings	Backup & jobs
Super admin	Yes	Yes	Yes	Yes	Read + export	Yes	Yes
Admin	Yes	Yes	Yes	Yes	Read + export	Yes	No
Treasurer	Read (no tab)	Read only	Yes	No	No	No	No
Secretary	Yes	Yes	No	No	No	No	No
Disciplinary officer	No	No	No	Yes	No	No	No

Loans, the spending limit and the Control Room

Role	Loans: lend, repay, take back, cancel	Choose the loan fund	Spending limit (Settings)	Email a member his statement	Control Room

Super admin	Yes	Yes	Yes	Yes	Yes
Admin	Yes	Yes	Yes	Yes	No
Treasurer	Yes	No	No	Yes	No
Secretary	No	No	No	No	No
Disciplinary officer	No	No	No	No	No

Security switches and account hygiene

Role	Change own password (screen)	Enrol own 2FA (screen)	Reset somebody else's 2FA	Switch the group's 2FA	Decide how payments meet fines
Super admin	Yes (My account)	Yes (My account)	Any account	Yes	Yes
Admin	Yes (My account)	Yes (My account)	Secretary & disciplinary	No	No
Treasurer	Yes (My account)	Yes (My account)	No	No	No
Secretary	Yes (My account)	Yes (My account)	No	No	No
Disciplinary officer	Yes (My account)	Yes (My account)	No	No	No

The two admin roles also keep the older panels on the Settings page (Settings → My password and Settings → Security), which carry the same form and the group's master switch. My account is the copy every role can reach.

13. Common tasks, step by step

The jobs the group actually does, in the order a hand touches the screen. Everything here is reachable from the office's own menu; nothing needs a developer unless the last three rows do.

Money and members

Task	Who does it	How
Log a member's payment	Super admin, admin, treasurer	Dashboard or Finance → tap the member → Weekly / Extra / Tea / Expense → amount, date, method, and the M-Pesa or bank message in the note → Save. Pending fines are paid down oldest-first if the group's switch is on.
Correct a payment	Super admin, admin, treasurer	The member's ledger → the row → Edit → change it and save. The old figures stay in the audit trail, so the correction is visible rather than silent.
Set the week's figures / opening balances	Super admin, admin, treasurer	Finance → Setup → the weekly amount, tea, week number, anchor and each member's opening balance ("Use all suggestions" fills them from the ledger) → Save. A save that would cut the members' total by a quarter or more asks again.
Post a whole week for everyone at once	Super admin, admin, treasurer	Finance → Setup → the week collection → Preview → Post. The undo sits beside it, because this is the one bulk write in the system.
Add or edit a member	Super admin, admin, treasurer	Members → Add a member (or open one → Edit) → the admission form: name, phone, ID, registration number, next of kin, photograph → Save.
Import a sheet of members	Super admin, admin, treasurer	Members → Import → download the template, fill it, upload it. A duplicate phone or an ID another member already holds is skipped and reported row by row — never overwritten.
Print a member's statement	Super admin, admin, treasurer	Members → the member → Statement → choose the period → PDF (to print or share) or Excel.
Issue a fine	Super admin, admin, disciplinary officer	Discipline (or the member's page) → the member → the infraction → amount → date → reason → Issue.
Settle a fine by hand	Super admin, admin	The member's page → Fines → Pay → the amount → Save.
Void a fine	Super admin, admin	The member's page → Fines → Void. Only for a fine that should never have been issued — never for one that has been paid.
See who owes fines, and what for	Super admin, admin, treasurer (reports); + disciplinary officer (own category)	Reports → Fines → Who owes what: search a member, choose the order, and tap a row to open his debt by fine type. Export the view for a meeting.
Email whoever is behind	Super admin, admin,	Reminders → tick the members → choose whether to include late arrears

	treasurer	and fines → add a note → Send. The screen waits, because each message is sent one at a time, and reports what happened member by member. A member who has already had this week's reminder is shown with the count and cannot be ticked — **Send anyway**, off by default, is the deliberate way round it, and the limit itself (1 a week by default) is set by an admin in Settings → Reminders.

Records, accounts and the system itself

Task	Who does it	How
Write and publish a minute	Super admin, admin, secretary	Minutes → New → title, date, the record (or Import a Word file) → Visible to members on or off → Save.
Upload a group paper	Super admin, admin, secretary	Docs → Upload a document → title, heading, the file (PDF or image, up to 8 MB), an optional description → Visible to members on or off → Upload.
Find out who changed a figure	Super admin, admin	Audit → filter by category, action, record type, who, dates or a word; switch on "Unusual only" → Export for the meeting.
Create an account	Super admin (any role); admin (secretary or disciplinary)	Settings → Accounts → Add account → name, email, password (8+ characters, letters and numbers), role → Add. Admins and treasurers are the super admin's to hand out.
Change your own password, or set up a second factor	Any role	My account — the Account link in the top bar, or My account in the sidebar. Current password, new password; or the second-factor panel, which shows a key to type into an authenticator app.
Turn someone's sign-in off	Super admin; admin (secretary or disciplinary)	Settings → Accounts → the account → Deactivate. Nothing is deleted, and the audit trail keeps its history.
Reset a forgotten password	Super admin; admin (secretary or disciplinary)	Settings → Accounts → the account → Reset password → a new one (letters and numbers, 8+). The account's other sessions end immediately.
Switch the group's two-factor on	Super admin only	Settings → Security → the master switch. Tell the admins to enrol from the same panel; the other roles have no screen for it yet (Annex D).
Take a copy of the database	Super admin only	Settings → Backup → read the two lines above the button (when a copy last left the machine, and what is only on the host) → Download. Keep it where the committee keeps the register, never in the repository.
Take the backup by hand (free host)	Super admin only	Control Room → Backups → Run now on nightly-backup. It makes the copy and sends it off the server in one go. The free host sleeps, so the 02:00 run usually does not happen: do this after any day money was recorded, and before anything risky. Do not set up an outside timer to keep the server awake; it spends the month's free hours.
Restore from an off-server copy	Super admin only	Control Room → Backups → the copy → Download. Then Restore below it: choose the file (the compressed file is read as it is), read what it says would be added or replaced, switch on maintenance mode, then confirm with your password and the word RESTORE. A safety copy of today is taken first.
Lend to a member	Super admin, admin, treasurer	Loans → Lend to a member → pick the member, the amount, the interest and the months → read the terms back → Lend. The first time, an admin chooses the loan fund and confirms the change it shows. Above the spending limit, add the minute that approved it.
Record a loan repayment	Super admin, admin, treasurer	Loans → the loan → Record a repayment → amount and date. The screen shows the split between principal and interest. Taking back a mistake works for the latest repayment only.
Email a member his statement	Super admin, admin, treasurer	Members → the member → choose the period → Email statement. It goes to the address on his record, as a PDF.
Run a scheduled job by hand	Super admin only	The jobs panel (from Settings) → Run now. The jobs are the nightly backup, the weekly audit check and the reminder sweep, and running one by hand is the same code as the timer.
Put a backup back	Whoever holds the server	`npm run restore:backup -- <file.json>` — a dry run first, `--confirm-write` to write it, and it refuses the live database unless it is told twice. Rehearse

		against a scratch database before you ever need it.
Chase members with no ID	Super admin, admin, treasurer	Members: the line at the top counts active members without a usable ID. Open each one and fill the ID in — the treasurer can do this too, as long as the field is empty; until the ID is there, that member cannot open his own record.
Trim the audit trail	Whoever holds the server	`npm run audit:prune -- --days=730 --confirm-write`. A dry run without the flag; the prune records itself, and the retention window is the committee's decision.

14. The money rules every user shares

One set of rules runs the ledger, the passbook, the funds and the reports. They live in one place in the code, which is why four screens can never disagree about a member's balance.

- **One week number for everybody.** It advances by itself every Friday and closes on the Thursday, pinned to East African time rather than the server's clock, because the treasurer's phone and the hosting company's clock are not in the same place.
- **Week 92 is the baseline.** The money for it is each member's opening balance — checked against the paper ledger — so the baseline week is never scored: it neither expects the weekly amount nor costs any tea.
- **What a member is asked for** is the weekly amount × the weeks that have closed and been scored. The week still running is never counted against him, and the day after its Thursday is when it starts to count.
- **What a member holds** is his opening balance + what he has paid since the cycle opened − what he has been asked for − the tea. Paying above the weekly amount is not swallowed: it raises what he holds. A closed week with nothing paid takes the weekly amount back off it — the accumulated credit or arrears the group works to.
- **Tea is automatic.** It is deducted from every member for every closed scored week whether or not anybody logged anything, it can never be in arrears, and each member can see his own total into the Group's Tea Fund.
- **A closed NILL week is flagged, never charged.** It is the shape of the constitution's §7.5 fine, but a fine has to be issued with its week and its reason — the system does not invent one.
- **A payment dated before the cycle opened** is credited to the opening week, where the money actually belongs.
- **A logged payment pays off pending fines first** — oldest first — only when the super admin has switched that on. Otherwise it counts as contribution.
- **Amounts are rounded to two decimals at the model**, so no path through the arithmetic can leave a balance a hair off and no two screens can differ by a cent.

15. Security, privacy and the audit trail

15.1 What is public and what is not

- **Public:** the group's name and logo, how many members there are, the totals each fund has raised, a seven-day intake figure, and the vision and mission. No member's name, balance or phone number is in any public response.
- **Behind the member's own ID:** his record, the group's documents, the minutes and the constitution. Every one of those endpoints re-checks the ID on every request, and the data is marked no-store so no browser, proxy or service worker keeps a copy after the page is closed.
- **Office-only:** everything else — the register, the ledger, the reports, the audit trail, the accounts and the settings.
- **Members' contact details** (email, next of kin) appear only on a member's own page, after he has proved his own number, and never on the office's public side.

15.2 The defences that matter in daily use

- **The gate is rate-limited**: five passbook lookups a minute, thirty a minute for the documents, minutes, constitution and group totals, and every refusal logged (with a hash of the number, never the number).
- **The office is rate-limited too**: 300 requests a minute per signed-in session, so a runaway retry loop or a stolen token cannot be used to hammer the database.
- **Uploads are checked by their content, not their label.** SVG and HTML are refused outright — both are markup wearing an image's content type — and anything that is not a PDF or an image is downloaded instead of displayed.
- **Minutes are cleaned on the way in** against the editor's own schema, so a script cannot be written into a minute and served to a member's phone.
- **Passwords are hashed, sessions expire in eight hours, and a password change ends the other sessions.** A lost second factor is cleared loudly and should be paired with a password reset.
- **No member data goes into the repository.** It has happened once in this project's history and the record was rewritten because of it; the rule now stands, and a check fails the build if a spreadsheet or dump is tracked again.

15.3 The audit trail — what it holds, and who reads it

- **Every write by a person is recorded**, on create, edit and delete, with a before-and-after snapshot: contributions, expenses, fines, members, settings, minutes, documents, accounts, sign-ins, backups and job runs.
- **It is append-only and chained.** An entry cannot be edited or deleted afterwards; a change to the chain is detectable, and `npm run verify:audit` is how that is checked.
- **Four categories, so the right question is one click away:** Money, People, Records, Settings.
- **Unusual entries are flagged** — an amount cut or raised, a contribution moved to another member or another fund, one re-dated, a member's phone, ID or carried-in balance changed, an account's role changed, a group-wide operation such as a ledger reset. Ordinary edits are not flagged, which is what makes the flags worth reading.
- **Who may read it:** the super admin and the admin only — the people who answer for the office. The treasurer and the secretary, whose own work it records, do not read it (the API answers 403 and the menu has no Audit entry), and neither does the disciplinary officer.
- **The screen receives only what it prints.** The stored snapshots contain whole member records — national ID, family, next of kin — and they are read to work out the flags and never sent to the browser.
- **The export is a real workbook** of exactly the view on screen, with an "Unusual" sheet, so a committee meeting can hold the same rows a person just read.
- **Retention is the committee's decision**, applied with `npm run audit:prune`; the prune records itself in what remains. The counts on screen cover the newest 2,000 matching entries and say so, because the collection only ever grows.

15.4 Backups

- **One file, the whole database**, document scans included, base64-encoded so a 5 MB scan does not become a 7 MB one. Member photographs are not inside it — they live on the image host — but the links are, so a restore re-attaches them.
- **Super admin only**, streamed a collection at a time so a small server never has to hold two copies in memory, and every download is written to the audit trail.
- **A slim copy** (`?slim=1`) leaves the bytes out: that one is for reading or emailing, not for restoring.
- **Version 2 format.** Any backup downloaded before 18 September 2026 is version 1 and cannot be trusted — a bug turned its dates into empty objects. Take a fresh copy.

- **A backup is the register.** It carries password hashes and every member's details, so it is kept where the committee keeps the register, never in the repository and never in a chat app.

16. What only one person can do — and why that matters

A role that exists on paper but only in one person's head is a single point of failure. These are the jobs the system concentrates, and what the committee should have ready before it needs them.

Job	Only who can	If that person is unavailable	What to have ready
Create an admin account; deactivate any admin	Super admin	No new admin can be brought in and no admin can be switched off.	The committee's sealed record of the super admin's sign-in.
Download a backup; run a scheduled job	Super admin	No fresh copy leaves the machine, and the reminder sweep cannot be run by hand.	Two people who know how to sign in as the super admin.
Switch the group's two-factor on or off	Super admin	The group's sign-in policy is frozen.	A decision recorded in the minutes before it is needed.
Reset a lost super admin password	Someone with the server	Nobody can sign in to the account that can fix accounts.	The server access, and `node src/scripts/resetSuperAdmin.js` documented where the committee can find it.
Restore a backup	Someone with the server	A damaged database cannot be put back.	A rehearsal: `npm run test:integration` and a restore into a scratch database.
Change the week cycle or opening balances	Super admin, admin, treasurer	The books cannot be corrected at a Thursday close.	Two of the three should have done it once, in a meeting.
Fill in a member's ID	Super admin, admin, treasurer	That member cannot open his own record, and the members' page keeps counting him.	Work the "no usable ID" count down to zero and keep it there.

Annex A — every screen, and who may open it

These are the route guards in the application, read straight off App.jsx. A role that opens a screen not listed for it is sent to its own landing page rather than shown an error.

Screen	Address	Who may open it	What it is for
Members' page	/	Anyone; a member's own figures need his ID	Group totals, his passbook, statement downloads, and the documents / minutes / constitution tabs
Constitution reader	/constitution	Members with a recorded ID	The constitution chapter by chapter, with his own verdict against each chapter
Sign in	/admin/login	Anyone with a valid account	Email and password; a second step when the account has two-factor on
Dashboard	/admin/dashboard	Super admin, admin, treasurer	The week's figures, the first eight members, the "Go to" panel, and the password form for roles without a Settings page
Settings	/admin/settings	Super admin, admin	Chama identity, fine types, accounts, own password, security, and (super admin only) backup
My account	/admin/account	Every signed-in role	Your own password and your own second factor — the only place three of the five roles can reach either
Members	/admin/members	Super admin, admin, treasurer	The register: add, edit, import, export, and the count of members with no usable ID
One member	/admin/members/:id	Super admin, admin, treasurer	His figures, his payments, his fines, his

			statement, his photo, resign, message him

Annex A (continued)

Screen	Address	Who may open it	What it is for
Finance (the ledger)	/admin/finance	Super admin, admin, treasurer	The member list with what each holds, and the one place money is logged
Finance setup	/admin/finance/setup	Super admin, admin, treasurer	The week cycle, opening balances, fund carry-ins, the whole-week collection and its undo
One member's ledger	/admin/finance/:id	Super admin, admin, treasurer	The logging panel for one member, opened over the list
Reports	/admin/reports	Super admin, admin, treasurer, secretary	Summary and trend, weekly reconciliation, performance, monthly totals, fines — each exportable
Minutes	/admin/minutes	Super admin, admin, secretary	Write a minute, import a Word file, publish to members, search the archive, delete
Reminders	/admin/reminders	Super admin, admin, treasurer	Who owes what, and the email that tells them
Documents	/admin/documents	Read: super admin, admin, treasurer, secretary. Write: super admin, admin, secretary	The group's papers and the headings they are filed under
Discipline	/admin/disciplinary	Super admin, admin, disciplinary officer	Issue a fine, read a member's fine record, export the group's disciplinary register
Audit	/admin/audit	Super admin, admin	Every change, filtered, with the unusual ones flagged and the view exportable
The old log address	/admin/log	—	Redirects to Finance; kept so an old bookmark or a shared link still lands usefully

Annex B — the API, by role

For whoever maintains this: the role list on each endpoint in backend/src/routes, which is the list the screens are built to match. Where a controller narrows it further, the note says so.

Endpoint	Who the API admits	Notes
/api/public/*	No sign-in	The member's ID is the credential, checked on every call, with the public rate limits
/api/auth/login, /api/auth/2fa/verify	No sign-in	Rate-limited per address and per connection
/api/auth/me, /me/password, /me/2fa/*	Any signed-in role	An account's own password, and its own second factor
/api/auth/admins*	super_admin, admin	Creating or managing an admin or a treasurer: super admin only. A plain admin may create, deactivate and reset only secretary and disciplinary accounts
/api/members	List: + disciplinary officer. Everything else: super_admin, admin, treasurer	The list is narrowed on the server for the disciplinary officer — name, phone, regNumber, nationalId, active — and the money figures are not computed for him. Writes to a member's nationalId, phone or nextOfKin are admin-only once a value is on the record
/api/contributions	super_admin, admin, treasurer	Create, bulk, edit, delete, import template
/api/expenses	super_admin, admin, treasurer	Create, edit, delete
/api/types	super_admin, admin, treasurer	Contribution and fund types
/api/ledger	super_admin, admin, treasurer	Member list, per-member log, setup, whole-week collection and its undo
/api/uploads	Member photo: super_admin, admin, treasurer. Chama logo: super_admin, admin	A photo is a member field; the logo is a settings field
/api/notifications	super_admin, admin, treasurer	The reminder list, the send, who has already been

		emailed this week and when, and the history of what went out; mail status
/api/reports	super_admin, admin, treasurer, secretary	Summary, trend, weekly, performance, monthly, fines, and every export
/api/audit	super_admin, admin	List and export; the screen is sent only what it prints
/api/documents	Read: super_admin, admin, treasurer, secretary. Write: super_admin, admin, secretary	Headings can be added and removed by the write roles
/api/minutes	Read: super_admin, admin, treasurer, secretary. Write: super_admin, admin, secretary	Sanitised against the editor's schema on the way in
/api/fines	Read and issue: super_admin, admin, disciplinary. Settle and void: super_admin, admin	The disciplinary officer's reads are narrowed to the disciplinary category
/api/fine-types	Read: super_admin, admin, disciplinary. Write: super_admin, admin	The disciplinary officer sees only the disciplinary category
/api/settings	super_admin, admin	twoFactorAuthEnabled and autoSettleFines are super admin only; the week-cycle fields are refused here by design
/api/backup	super_admin	The whole database, or a slim copy without the document bytes
/api/jobs	super_admin	What the jobs are, when they run next, what they last did, and run one now

Annex C — the words this system uses

Word	What it means here
Chama	The self-help group itself; in this deployment, Wazo Moja Self-Help Group.
Member's ID (national ID)	The number the office records on a member's file. It is the key to his own record and to the members' area. Spaces, dashes and slashes are ignored; a passport number's letters are accepted.
Registration number	The group's own membership number. It appears in the register and on statements, and it unlocks nothing.
Passbook	The member's own page: what he holds, what he has paid week by week, and any fines outstanding.
The ledger	The office's money screen: the member list with what each holds, and the one place payments are logged.
Week cycle	One shared week number for the whole group. It advances every Friday and closes on the Thursday, pinned to East African time.
Baseline week (week 92)	The opening week of the digital books. It is never scored: the money for it is each member's opening balance.
Scored week	A closed week that counts: it expects the weekly amount from every member, and costs them the tea.
NILL week	A closed week in which a member paid nothing. It is flagged for the constitution's §7.5 fine, but the fine is never charged automatically.
Arrears / credit	What a member owes, or is ahead by, after what he has been asked for and the tea are taken off what he holds.
Tea (chai)	The group's weekly tea contribution, deducted from every member for every closed scored week, with no entry needed from anybody.
Fund	One of the group's own pots — tea, welfare, registration — as opposed to a member's personal contribution.
Opening balance	Each member's carried-forward money at the baseline week, checked against the paper ledger before the books opened.
Fine type	A catalogue entry for an infraction, in one of two categories: financial (the office's) or disciplinary (the disciplinary officer's). Each carries a default penalty.

Minutes	The record of a meeting, written and published by the secretary; a switch decides whether members may read it.
Document vault	The group's papers — title deeds, certificates, registrations — filed under headings the office controls, each published to members or held back.
The gate	The ID check on the public side of the application. It is the only credential a member ever has.
Audit trail	The append-only, chained record of every change a person made, with the values before and after.
The backup	The downloadable file holding the whole database, documents included. It is treated exactly as the register is treated.

Annex D — what was tightened on 22 September 2026

This annex began as a list of places where the older notes and the code disagreed. Six were found, five were fixed in the code and the sixth was a note that had gone stale, so the list below is what changed rather than what is broken. It stays in the document because the committee should be able to see what moved and why.

- **The treasurer keeps the member register — and always did.** The older note said the treasurer could not manage member accounts; the API has always allowed it (list, one member, statements, create, edit, resign, import, export, photographs), and the committee chose to keep it that way. What changed is the corner of it that is not his: a member's **ID number, phone number and next of kin** may be filled in by anyone in the office while the field is empty, but replaced only by an admin. See section 8.6.
- **An admin can no longer be offered a treasurer it cannot create.** The Add-account dialog offered Treasurer to a plain admin while the API refused it — and, worse, a request the API did not recognise was quietly treated as *admin*, so a treasurer created from the super admin's own dialog was in fact an admin account with admin rights while the screen said "Treasurer added". Both halves are fixed: the super admin creates treasurers properly, an admin is offered only the secretary and disciplinary accounts, and an unknown role is refused by name.
- **The disciplinary officer's member list is narrowed on the server.** The older note claimed the officer saw only a name and a phone number; the shared list endpoint was in fact returning every member's family, contacts, notes, photograph and balance to him. It now answers that role with five fields — name, phone, registration number, ID and whether the member is active — and stops computing the money figures for him altogether. A screen that does not show something is not a permission, and the register is the one collection here that holds everybody.
- **Every role now has a screen for its own account.** The password form and the second-factor panel used to live on the dashboard (open to the three money roles) and on the Settings page (admin-only), so the treasurer could not enrol a second factor at all and the secretary and disciplinary officer could do neither that nor change their own passwords. My account (`/admin/account`) is open to every signed-in role — which is what makes the group's two-factor switch worth flipping, because now it can protect every account rather than only the admins'.
- **The role document was rewritten against the code.** ROLES_AND_PERMISSIONS.md now says what the system does: the treasurer's register rights, the secretary's minutes, the disciplinary officer's narrowed list, who may create which account, and where each role's own password is changed.

Two exceptions that are deliberate, not oversights

- **The treasurer may read the minutes** through the API even though the menu gives him no Minutes tab. The routes say every office role may read them, because the money agreed in a meeting is exactly what a treasurer has to account for. Writing them belongs to the secretary, the admin and the super admin.

- **The week cycle and opening balances are changed from Finance → Setup**, which the treasurer can use, even though `/api/settings` is admin-only. He is the person who needs them at go-live. A save that would move the books hard asks to be confirmed, and it is audited as one change.

  If the committee ever revisits the first one — whether the treasurer should keep the register at all, or keep it read-only — the change is a short one in backend/src/routes/memberRoutes.js plus a role check on the Members screen. It is a decision about trust, not a technical question.

Annex D2 — what was added in October 2026

Since the guide was first written the system gained six things and a super-admin screen. They are described where they belong (sections 6 to 8, 12 and 13); this is the list in one place.

- **The Control Room** (section 6.5): sessions, maintenance mode, closing the books, switches, restore, merging two members and a generated permissions table.
- **Loans to members** (section 7.5): flat interest, monthly instalments, behind-schedule tracking, a card on the member's page.
- **A spending limit** (section 7.2): above it an expense or loan must say which minute approved it.
- **Emailed statements** (section 7.2): a member's own PDF, sent to his address.
- **Backups that survive a free host** (section 6.4): each backup is also kept in Cloudinary.
- **Server error alerts** (section 6.5): faults recorded and emailed once per fault per six hours.
- **A truthful last-seen** (section 6.5): accounts used before sign-in tracking began no longer read "never signed in".
- **The audit trail is for the admins only** (section 15.3). The treasurer and the secretary used to read it; the group withdrew that. The menu entry is gone for both and the API refuses them.

  One decision shapes how the group runs: no outside timer is used to keep the free server awake, because that spends the free hours. The scheduled backup therefore usually does not run on its own; the super admin takes it by hand (section 6.4).

Annex E — keeping this true

- **This document is generated, not typed.** The script is build_user_interaction_guide.py in the repository root: run `python build_user_interaction_guide.py`, then the PDF step, and both files are rebuilt from the same text.
- **Its sources are in the repository**, so every claim can be checked: the role guards in backend/src/routes/*.js, the route guards in frontend/src/App.jsx, the menus in frontend/src/components/layout/navItems.jsx and WorkspaceNav.jsx, the role landing pages in frontend/src/utils/roleHome.js, the credential rule in backend/src/utils/memberCredentials.js, and the screens under frontend/src/pages/.
- **When a role changes**, work the checklist in ADDING_NEW_ROLES_GUIDE.md — the User model's enum, the requireRole lists on the routes, RoleGuard in App.jsx and roleHome() — and then re-read sections 3, 5.3, 11, 12 and Annexes A, B and D here. Those are the places a new role has to appear, and the places a forgotten one will show as a contradiction.
- **When a screen appears or moves**, check Annex A; when an endpoint's role list changes, check Annex B; when a permission is tightened, add it to Annex D and to the plain-English addendum in WHAT-WE-ADDED.md, which is the copy the committee reads.
- **Who should own this document:** the committee's secretary, with the developer's help, since it is the one file that explains to a new office holder what the group has decided about who may see and do what.

How this copy was produced

- Read from the source in this repository on 22 September 2026, after the permissions pass described in Annex D (the credential rule, the narrowed disciplinary list, the account screen, and the corrected role document).

- Role lists taken from the code, not from older guidance; ROLES_AND_PERMISSIONS.md was rewritten in the same pass so the two now agree.
- Generated as a Word document from this repository's own script, with the contents page and page numbers filled in by Word, then exported to PDF from the same file.
- Nothing in it was copied from a member's record: it describes the system, and no member, balance, phone number or ID appears anywhere in it.